

Laboratorio 1: File Path Traversal

Marco teórico

La vulnerabilidad de File Path Traversal o directory traversal ocurre cuando una aplicación web utiliza entradas del usuario de forma no segura para construir rutas del sistema de archivos sin realizar una validación o sanitización estricta.

Su funcionamiento es que un atacante inserta secuencias de escape como ../ en Linux o ..\ en sistemas Windows para retroceder desde el directorio raíz configurado en el servidor web e ingresar a directorios restringidos del sistema operativo.

Impacto en la tríada CIA:

Confidencialidad: su impacto es alto ya que permite la lectura no autorizada de código fuente y archivos de configuración de credenciales y datos sensibles del sistema.

Integridad/ Disponibilidad: Es bajo si solo son ataques de lectura, pero escalan su riesgo si se combinan con vulnerabilidades de escritura arbitraria o se comprometen claves maestras.

OWASP: Corresponde a la categoría **A01:2025 - Broken Access Control**

[Broken Access Control | OWASP Foundation](#)

Para la defensa se debe de aplicar el principio de mínimo privilegio y reemplazar el manejo directo de rutas locales mediante listas blancas o identificadores indirectos e inmutables.

Laboratorio

Nombre del laboratorio: File path traversal, simple case

Nivel: Apprentice

Tipo de explotación: File path traversal

Objetivo del laboratorio: Recuperar y visualizar el contenido del archivo /etc/passwd del servidor.

Vulnerabilidad: La aplicación procesa la solicitud de imágenes mediante un parámetro URL (filename). El backend lee directamente este valor e intenta resolver el recurso en el disco duro sin restringir que la secuencia de búsqueda salga de la carpeta /var/www/images.

Procedimiento

Payload

Payload utilizado: ../../etc/passwd

Suponemos que la aplicación almacena las imágenes en la ruta
/var/www/app/resources/images/

El primer ../ retrocede a /var/www/app/resources/

El segundo ../ retrocede a /var/www/app/

Y el tercer ../ retrocede a la raíz del sistema de archivos.

La adición de etc/passwd le indica al archivo que abra dicho archivo del directorio /etc/

Al no existir una validación que elimine los caracteres .. o /, el servidor ejecuta la lectura de forma nativa.

Mitigación recomendada

Para solucionar esta vulnerabilidad se deben de implementar prácticas de programación seguras:

- Evitar la entrada directa: no pasar nombres de archivos ni rutas provenientes de entradas del usuario a las APIs del sistema de archivos. Utilizar identificadores numéricos o claves hash asociadas a una base de datos.
- Validación:
- Verificación de ruta: